PRIVILEGED AND CONFIDENTIAL · PREPARED FOR LEGAL REVIEW

Brief for Advocate Review

Kabuor ERP: privacy notice, terms of service and data protection compliance under the laws of Kenya

---

To: the Advocate of the High Court of Kenya instructed to review Kabuor ERP's legal documents.

From: David Kiragu, Kabuor Builds.

Enclosed with: Legal and Compliance Pack, KAB-LEG-001 (22 pages).

Document control

Document	KAB-LEG-002, Brief for Advocate Review
Date	21 October 2026
Client	Kabuor Builds (David Kiragu), dkiragunderitu@gmail.com
Product	Kabuor ERP, a cloud business system for Kenyan SMEs
Documents for review	Annex A: Privacy notice. Annex B: Terms of service. Enclosure: Legal and Compliance Pack (KAB-LEG-001)
Response requested	A marked-up copy of Annexes A and B, written answers to the questions in section 3, and a fee note

Contents

1. Background 3

2. Scope of instructions 4

3. Questions for the advocate 5

4. Documents enclosed 6

Annex A: Privacy notice 7

Annex B: Terms of service 10

1. Background

Kabuor ERP is cloud software that Kenyan small and medium businesses use to issue KRA eTIMS invoices, receive M-Pesa payments, keep stock, buy from suppliers, run payroll, manage customers, and get reports and suggestions from AI agents. It is offered by subscription (KSh 1,500 to 9,500 per business per month) and hosted on Render (Frankfurt, Germany) with a PostgreSQL database on Neon. An AI provider in the United States (Anthropic) powers the assistant and agents; nightly encrypted backups are stored with GitHub (United States).

Kabuor Builds acts as a **data controller** for the accounts of the businesses and people who sign in, and as a **data processor** for the records each business keeps about its own customers, suppliers and employees. The privacy notice and terms in the annexes were drafted to the Data Protection Act, 2019 and the 2021 Regulations; the enclosed Compliance Pack sets out the analysis, the record of processing, the impact assessment, the retention schedule, the transfer register and a security self-assessment. The owner is also preparing the business for sale, for which a separate Information Memorandum exists.

2. Scope of instructions

1. Review the privacy notice (Annex A) and terms of service (Annex B) for compliance with Kenyan law and for enforceability, and mark up any changes.
2. Confirm or correct the analysis in the Compliance Pack, in particular sections 3 (registration), 4 (record of processing), 6 (impact assessment), 7 (retention) and 8 (transfers abroad).
3. Answer the questions in section 3 of this brief.
4. Advise whether a separate data processing agreement should be offered to business customers in addition to the processor clauses in the terms.
5. Advise on the steps and documents needed to sell the software and its intellectual property (assignment under the Copyright Act, 2001; warranties; escrow).

Out of scope unless agreed: drafting new agreements from scratch, filing with the ODPC or KRA, and litigation advice.

3. Questions for the advocate

Table 1. Questions

#	Question	Where in the documents
1	Is the split between controller (accounts) and processor (business records) correct, and do the processor clauses in the terms satisfy section 42 of the Act and Regulation 24 as the written contract, or is a separate data processing agreement needed?	Annex B, clause B6; Pack s. 4
2	Kabuor Builds is below the registration thresholds (Regulation 13(2)). Is voluntary registration as both controller and processor advisable, and is the entity structure (business name or limited company) adequate for registration and for a sale?	Pack s. 3
3	Kenya has no adequacy decisions. Is reliance on Regulation 41(1)(b) (our own assessment plus each provider's binding terms) sufficient for transfers to Germany and the United States, or should consent or other safeguards be used?	Annex A, clause A6; Pack s. 8
4	Does sending business records to an AI provider for the assistant and agents need express consent or contractual wording beyond listing it as a sub-processor?	Annex A, clauses A5 and A6
5	Is the profiling disclosure (customer segments, agent suggestions, credit holds that a person can override) sufficient under sections 31 and 35 of the Act?	Annex A, clause A5; Pack s. 6
6	Is the erasure approach correct: removing contact details and conversations but keeping the name and KRA PIN on issued invoices for five years under the Tax Procedures Act, s. 23, relying on Regulation 12(4)?	Annex A, clause A9; Pack s. 5 and 7
7	Is the retention schedule consistent with the Tax Procedures Act, the Employment Act (s. 74) and any sector rules for hospitality, retail and distribution customers?	Pack s. 7
8	Kabuor reads M-Pesa payment confirmations but never holds customer funds. Confirm that no authorisation is needed under the National Payment System Act, 2011.	Pack s. 2
9	Is the limitation of liability (12 months' fees; no indirect loss) enforceable against SMEs, given the Consumer Protection Act, 2012 and the Law of Contract Act?	Annex B, clause B8
10	Is acceptance of the terms by opening an account (click-through) adequate, or should a signed or checkbox acceptance be recorded?	Annex B, clause B1
11	Regulation 26 requires Kenyan processing for basic education and primary or secondary health care. Is the warning to schools and clinics in the terms adequate, or should such customers be refused?	Annex B, clause B7
12	Incident INC-2026-001 (a published signing key, no evidence of access, closed without notification). Do you agree no notification was required under section 43 and Regulation 37?	Pack s. 10
13	For the sale: what assignment, warranties and escrow terms do you recommend, and are there any issues with the use of open-source components?	Information Memorandum s. 10 and 12

4. Documents enclosed

Table 2. Documents

Reference	Document	Notes
KAB-LEG-002	This brief, with Annex A (privacy notice) and Annex B (terms of service)	The annex wording is exactly what the live service shows at /privacy and /terms, numbered here for mark-up
KAB-LEG-001	Legal and Compliance Pack	Legal register; ODPC registration; record of processing; DPIA; data subjects' rights; retention; transfers; breach procedure; incident register; security self-assessment; action plan
KAB-IM-001	Information Memorandum (on request)	For advice on the sale

Annex A: Privacy notice

Wording as shown at /privacy on 21 October 2026. Clause numbers are added for review only. The contact email and hosting region are filled in from server settings (shown here as on the live service).

A1. Introduction

A1.1 Kabuor ERP is run by Kabuor Builds in Kenya. This notice explains what personal data the service holds, why, who sees it, and your rights under the Data Protection Act, 2019.

A2. Two kinds of data, two roles

A2.1 **Your account** (the business and the people who sign in): Kabuor Builds decides how this is used, so we are the **data controller**.

A2.2 **The records you keep** (your customers, suppliers, employees, payslips, invoices): your business decides what to record and why, so your business is the **controller** and Kabuor Builds is your **data processor**. We only use it to run the service for you.

A3. What we collect

A3.1 Business details: name, KRA PIN, phone, email, county, VAT status, M-Pesa shortcode.

A3.2 People who sign in: name, email, phone, role, a scrambled (hashed) password, and two-step sign-in settings.

A3.3 Records you enter: customers, invoices, payments, stock, purchases, and, if you use payroll, employee details such as ID, KRA PIN, NSSF, SHA and bank or M-Pesa details.

A3.4 Payment details Safaricom sends us when someone pays your Paybill or Till: the amount, M-Pesa receipt, phone number and name.

A3.5 Basic technical logs (time, address of the request, errors) to keep the service secure and working.

A3.6 If you use tracking links and the online shop: which link someone clicked, a random browser id (cookie *kv*), the link they came through (cookie *kref*), whether it was a phone, and what they asked. No advertising cookies are used. Your sign-in is kept in your browser's storage, not a cookie.

A4. Why we use it

A4.1 To provide the service you signed up for (contract).

A4.2 To meet legal duties, such as sending invoices to KRA eTIMS and keeping tax records (legal obligation).

A4.3 To keep accounts secure and prevent fraud (legitimate interest).

A4.4 Marketing messages only go to customers you have not marked as having opted out, and every campaign respects that choice.

A4.5 We do not sell personal data, and we do not use your records to advertise to anyone.

A5. Profiling, automated suggestions and children

A5.1 **Profiling and automated suggestions.** Kabuor Intelligence groups a business's customers (for example "best customers" or "at risk") and its agents suggest actions such as reminders or purchase orders. These help the business decide; no decision with a legal or similarly significant

effect on a person is made by the system alone. A credit limit that holds an invoice can always be overridden by a person, and you can ask the business for a human review of any decision about you (section 35 of the Act).

A5.2 The service is for businesses and is not meant for children under 18.

A6. Who else sees it, and transfers outside Kenya

A6.1 **Hosting**: the application runs on Render (Frankfurt, Germany) and the database on Neon. Data is therefore stored outside Kenya.

A6.2 **KRA** (Kenya): invoices are sent to eTIMS when your business is VAT-registered.

A6.3 **Safaricom** (Kenya): when you use M-Pesa features (payment notices, prompts, subscriptions).

A6.4 **Africa's Talking** (Kenya): to send sign-in codes and messages by SMS, when SMS is switched on.

A6.5 **Anthropic** (United States), for Msaidizi and the agents: the question and the records needed to answer it are sent to produce the answer. It suggests; a person approves anything that changes your books.

A6.6 **GitHub** (United States): the nightly database backup, encrypted before it leaves our servers and kept 30 days.

A6.7 **Sentry**: error reports, set up not to include personal data such as names, emails or request addresses.

A6.8 Anyone the law requires us to share with, such as a court order.

A6.9 **Transfers outside Kenya.** We only send personal data abroad on the grounds in sections 48 and 49 of the Act and regulations 40 and 41: under written terms with each provider that bind them to protect it, to providers whose security we have assessed, and only what the service needs. We keep a record of each kind of transfer and give it to the Data Commissioner on request.

A7. How long we keep it

A7.1 While your account is open, reviewed at least once a year (regulation 19). Tax law (Tax Procedures Act, section 23) requires business records to be kept for at least five years, so your business should export or keep its records for that long. When you ask us to close your account, we delete or anonymise your data within 90 days, unless you ask us to keep it longer or the law requires it.

A8. How we protect it

A8.1 Encrypted connections (HTTPS) and hashed passwords; secrets such as M-Pesa and KRA keys are encrypted at rest.

A8.2 Each business only ever sees its own records; inside a business, each role only sees what its job needs.

A8.3 Optional two-step sign-in, and "sign out everywhere".

A8.4 Daily backups, kept separately.

A8.5 If a breach puts personal data at real risk, we tell the Data Commissioner within 72 hours and the people affected without delay (section 43). For records we process for a business, we tell that

business within 48 hours so it can do the same.

A9. Your rights

A9.1 You can ask to be told what we hold about you, get a copy, have it corrected, move it to another provider, object to its use, stop direct marketing, or have it deleted where the law allows. For records a business keeps about you (for example as its customer or employee), ask that business first; the app lets it send you your data and erase it, and we help it answer. Write to the contact email shown on the notice.

A9.2 The law sets how fast we answer (Data Protection (General) Regulations, 2021): a copy of your data within **7 days**; correction within **14 days**; erasure within **14 days**; stopping direct marketing within **7 days**; moving your data to another provider within **30 days**. Records that tax or employment law requires a business to keep (such as issued invoices) can’t be erased until that period ends; we tell you what was kept and why.

A9.3 You can also complain to the Office of the Data Protection Commissioner (odpc.go.ke).

A10. Changes

A10.1 If we change this notice in a way that matters, we will tell account owners in the app before it takes effect.

Annex B: Terms of service

Wording as shown at /terms on 21 October 2026. Clause numbers are added for review only.

B1. Agreement

B1.1 These terms are an agreement between your business and Kabuor Builds for the use of Kabuor ERP. By opening an account you agree to them on behalf of your business.

B2. The service

B2.1 Kabuor ERP helps you invoice, take payments, keep stock, run payroll and keep your books. It sends invoices to KRA eTIMS and reads M-Pesa payments when you connect them. We aim to keep it available at all times but can't promise it will never be interrupted; we tell you in the app about planned maintenance.

B3. Free trial and paying

B3.1 New businesses get a 30-day free trial with every feature.

B3.2 After the trial and 7 more days' grace, your records stay readable and downloadable, but adding and changing them waits until you choose a plan.

B3.3 Plans are paid in Kenyan shillings, in advance, monthly or yearly (a year costs ten months). Prices are shown in Settings → Plan & billing; we give 30 days' notice of any price change.

B3.4 Paid time is not refunded if you stop early, except where the law requires.

B4. Your responsibilities

B4.1 Keep sign-in details private, and only give access to people who need it.

B4.2 The figures, tax returns and payroll you file are your responsibility. Kabuor ERP calculates PAYE, NSSF, SHA, the Housing Levy and VAT from the current rules, but check them and get professional advice where needed.

B4.3 You must have a lawful basis to record and message your customers and employees, and respect their opt-outs.

B4.4 Don't use the service for anything illegal, or try to reach other businesses' data.

B5. Your data

B5.1 Your records belong to your business. You can export them at any time. We handle personal data as described in the privacy notice, acting as your processor for the records you keep.

B6. Processing personal data for you

B6.1 For the records you keep, your business is the data controller and Kabuor Builds is your data processor. These terms are the written contract that section 42 of the Data Protection Act and regulation 24 require.

B6.2 **What, how long and why**: we process your customers', suppliers', leads' and employees' details (names, phone numbers, emails, KRA PINs, ID and NSSF/SHA numbers, pay and bank or M-Pesa details, invoices, payments and messages) for as long as your account is open, only to provide the service.

B6.3 **Your instructions**: we act only on your instructions, given through the app and these terms. If we think an instruction breaks the law, we tell you.

B6.4 **Confidentiality**: everyone who works on the service is bound to keep your data confidential.

B6.5 **Security**: the technical and organisational measures in the privacy notice, kept up to date.

B6.6 **Sub-processors**: you authorise the providers listed in the privacy notice. We give you 30 days' notice in the app before adding or replacing one, so you can object; each is bound by written terms like these, and we stay responsible for them (regulation 25).

B6.7 **Helping you**: we help you answer people's requests, carry out impact assessments, and handle breaches, which we report to you within 48 hours of becoming aware.

B6.8 **At the end**: when the agreement ends you choose to take your records or have them returned; after 30 days we delete them, except where the law requires us to keep them.

B6.9 **Audit**: on reasonable notice, we give you the information you need to check we meet these terms, including the results of our security reviews.

B7. Schools and health providers

B7.1 The law requires personal data from basic education and from primary or secondary health care to be processed in Kenya or to keep a copy there (regulation 26). Kabuor is hosted outside Kenya, so don't use it for learners' or patients' records until Kenya hosting is offered.

B8. Liability

B8.1 We are responsible for running the service with reasonable care and skill. We are not liable for indirect losses (such as lost profit) or for losses caused by information you entered, by KRA, Safaricom or other services being unavailable, or by events outside our control. Our total liability in any year is limited to what you paid us in the 12 months before the claim. Nothing here limits rights you have under the Consumer Protection Act or other law that can't be excluded.

B9. Ending the agreement

B9.1 You can close your account at any time. We may suspend an account that breaks these terms or is unpaid after the grace period, after telling the owner. On closing, you have 30 days to export your records before they are deleted as the privacy notice describes.

B10. Law and disputes

B10.1 These terms are governed by the laws of Kenya. We will first try to settle any dispute by talking; if that fails, the courts of Kenya decide.

B11. Contact

B11.1 Questions about these terms: the contact email shown on the terms page.